Modelo de amenazas — Sistema de Banca en Línea (SBL) — Banco Modelo, S.A.

Owner: Luis Francisco Gámez Rodriguez
Reviewer: Docente — Seguridad en Aplicaciones (093-013)
Contributors: Luis Francisco Gámez Rodriguez
Release Date: Wed Oct 07 2026

Executive Summary

High level system description

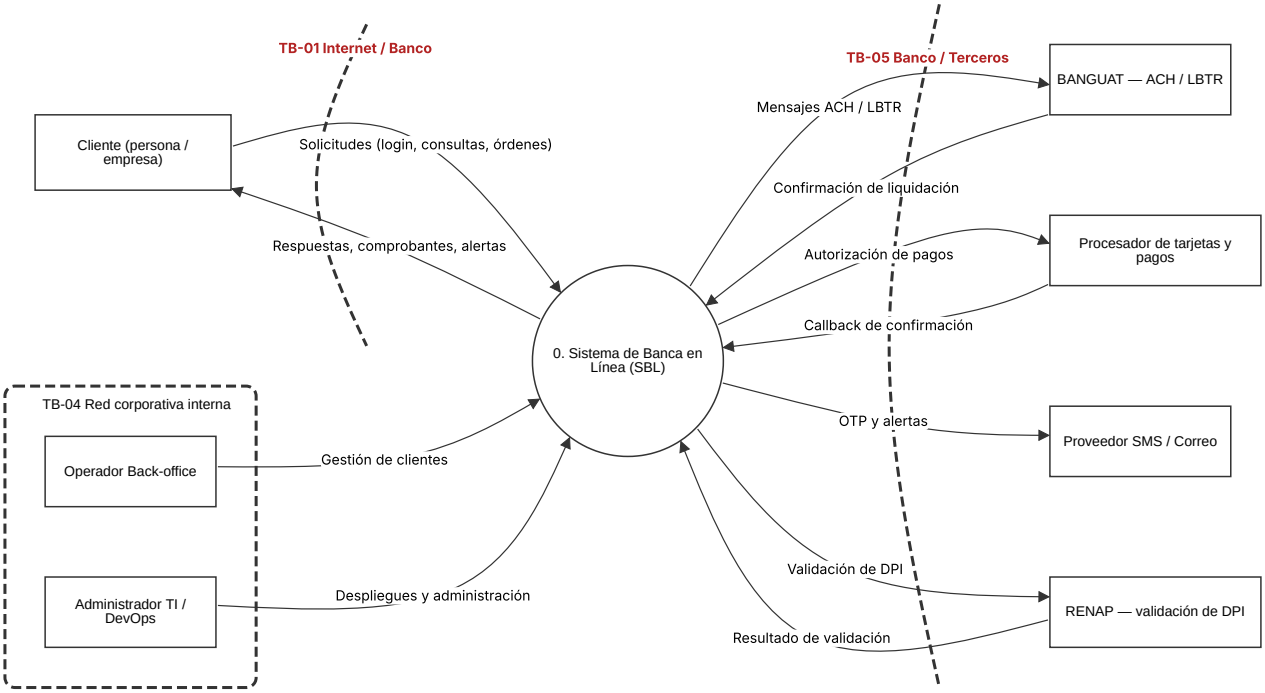
Modelo de amenazas (caso académico) de la banca en línea de una entidad ficticia: canales web y móvil, API Gateway, servicios de identidad, cuentas, transferencias, antifraude, middleware ESB, core bancario e integraciones con BANGUAT (ACH/LBTR), procesador de tarjetas, proveedor SMS y RENAP. Metodología: DFD + STRIDE, priorización Riesgo = Probabilidad x Impacto. Versión 1.0.

Summary

Total Threats	49
Total Mitigated	0
Total Open	49
Open / Critical Severity	6
Open / High Severity	26
Open / Medium Severity	17
Open / Low Severity	0

DFD Nivel 0 — Contexto

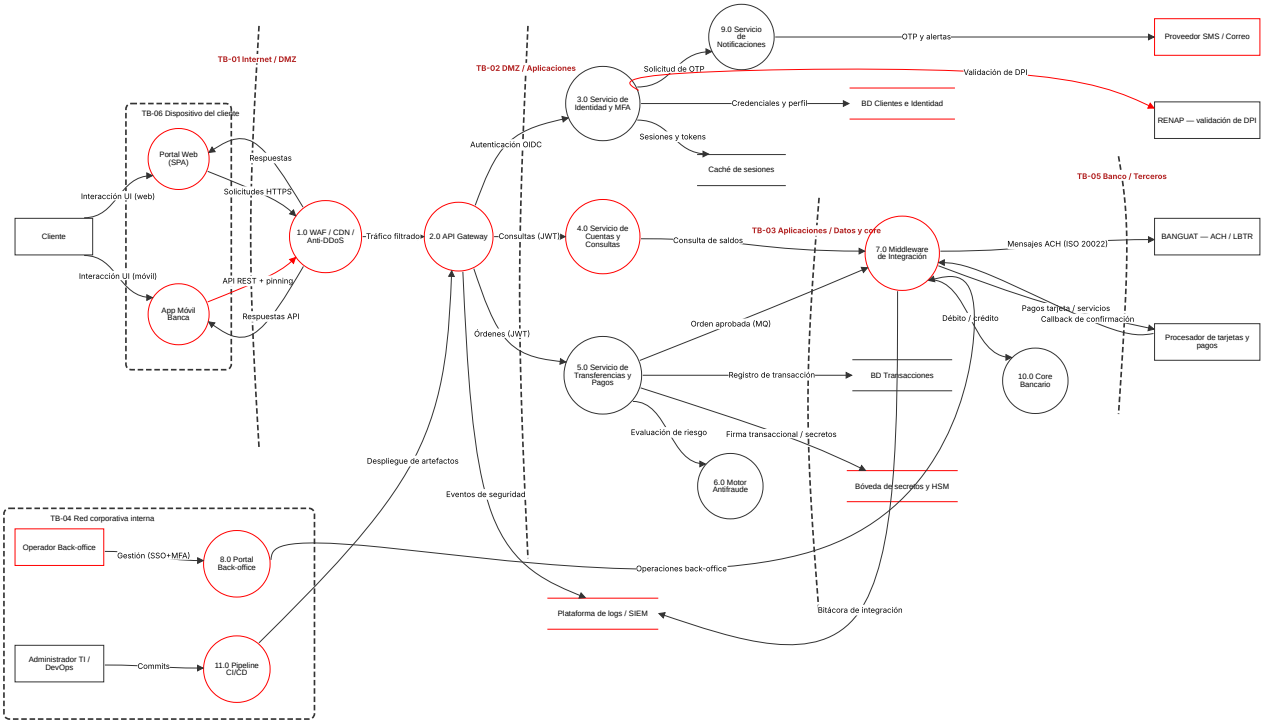
Contexto general de la banca en línea, usuarios y sistemas externos.



DFD Nivel 0 — Contexto

DFD Nivel 1 — Procesos principales

Procesos, almacenes, flujos y fronteras de confianza de la banca en línea.



DFD Nivel 1 — Procesos principales

Portal Web (SPA) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
46	T-46 Cross-Site Scripting (XSS) en el portal	Tampering	High	Open	12	Alias de beneficiario o descripción de transferencia con script que roba la sesión o altera la interfaz. Riesgo inherente: P3 x I4 = 12 (Alto). Riesgo residual: 3 (Bajo).	Codificación de salida, CSP estricta, sanitización, frameworks con auto-escape. Detectivo: Reportes CSP y alertas WAF. Correctivo: Corrección y limpieza de datos almacenados. Tratamiento: Mitigar | Iniciativa: R-10 | Responsable: Equipo Banca Digital | Fecha objetivo: 2027-03-31

App Móvil Banca (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
16	T-16 Modificación de la app (repackaging / hooking)	Tampering	High	Open	12	Ingeniería inversa y hooking (Frida) para saltar validaciones del cliente o distribuir una app falsa. Riesgo inherente: P3 x I4 = 12 (Alto). Riesgo residual: 6 (Medio).	Ofuscación, RASP, Play Integrity / App Attest, ningún control de seguridad solo en el cliente. Detectivo: Rechazo de attestation inválida y monitoreo de tiendas no oficiales. Correctivo: Baja de apps falsas y bloqueo de versiones comprometidas. Tratamiento: Mitigar | Iniciativa: R-10 | Responsable: Equipo Banca Digital | Fecha objetivo: 2027-03-31
17	T-17 Almacenamiento inseguro en el dispositivo	Information disclosure	Medium	Open	9	Tokens o datos en almacenamiento no cifrado (SharedPreferences/plist). Riesgo inherente: P3 x I3 = 9 (Medio). Riesgo residual: 3 (Bajo).	Android Keystore / iOS Keychain, no almacenar datos sensibles, MASVS-STORAGE. Detectivo: Pruebas MASTG en cada versión. Correctivo: Publicación de versión corregida e invalidación de tokens. Tratamiento: Mitigar | Iniciativa: R-10 | Responsable: Equipo Banca Digital | Fecha objetivo: 2027-03-31

1.0 WAF / CDN / Anti-DDoS (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
12	T-12 Ataque DDoS al portal y a las APIs	Denial of service	High	Open	16	Ataques volumétricos o de capa 7 dejan sin servicio la banca en línea. Riesgo inherente: P4 x I4 = 16 (Alto). Riesgo residual: 6 (Medio).	Servicio anti-DDoS gestionado, reglas de capa 7, autoescalado, caché de estáticos. Detectivo: Monitoreo de tráfico y alertas del proveedor. Correctivo: Activación del playbook DDoS con el proveedor. Tratamiento: Mitigar + Transferir (SLA del proveedor anti-DDoS) | Iniciativa: R-14 | Responsable: Arquitectura / Operaciones TI | Fecha objetivo: 2027-09-30

2.0 API Gateway (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
13	T-13 Abuso de API y envío masivo de OTP (SMS pumping)	Denial of service	High	Open	12	Llamadas automatizadas sin límite agotan recursos o generan miles de SMS con costo para el banco. Riesgo inherente: P4 x I3 = 12 (Alto). Riesgo residual: 4 (Bajo).	Rate limiting y cuotas por cliente y endpoint; máximo de OTP por sesión; CAPTCHA en endpoints anónimos. Detectivo: Alertas de consumo anómalo de SMS y de APIs. Correctivo: Bloqueo de origen y ajuste de cuotas. Tratamiento: Mitigar | Iniciativa: R-04 | Responsable: Arquitectura / DevSecOps | Fecha objetivo: 2026-12-31
14	T-14 Endpoints internos o versiones obsoletas expuestas	Elevation of privilege	High	Open	15	Rutas administrativas o versiones antiguas de la API (/v1) quedan publicadas sin los controles actuales. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	Inventario de APIs, deny-by-default, retiro de versiones obsoletas (OWASP API9:2023). Detectivo: Descubrimiento periódico de APIs y comparación con inventario. Correctivo: Despublicación inmediata de la ruta. Tratamiento: Mitigar | Iniciativa: R-04 | Responsable: Arquitectura / DevSecOps | Fecha objetivo: 2026-12-31
44	T-44 Explotación de vulnerabilidad conocida (CVE) en DMZ	Elevation of privilege	High	Open	15	Componentes sin parches en el gateway o contenedores permiten ejecución remota de código. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	Gestión de parches, hardening CIS, escaneo de imágenes y de vulnerabilidades. Detectivo: Escaneo continuo y EDR en hosts. Correctivo: Aislamiento del nodo, reconstrucción desde imagen limpia. Tratamiento: Mitigar | Iniciativa: R-05 | Responsable: Infraestructura y Redes | Fecha objetivo: 2026-11-30

4.0 Servicio de Cuentas y Consultas (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
9	T-09 Acceso a cuentas de otros clientes (IDOR / BOLA)	Elevation of privilege	Critical	Open	20	Cambiando el identificador de cuenta en la petición un cliente consulta saldos y movimientos de otro. Riesgo inherente: P4 x I5 = 20 (Crítico). Riesgo residual: 5 (Bajo).	Autorización a nivel de objeto basada en el 'sub' del token; identificadores no secuenciales; pruebas automatizadas de autorización. Detectivo: Alerta cuando un usuario consulta varias cuentas que no le pertenecen. Correctivo: Bloqueo del usuario, corrección del endpoint y notificación según regulación. Tratamiento: Mitigar | Iniciativa: R-02 | Responsable: Equipo Banca Digital | Fecha objetivo: 2026-12-31
10	T-10 Exposición excesiva de datos en respuestas	Information disclosure	High	Open	12	La API devuelve el objeto completo (DPI, dirección, datos internos) y el front-end solo oculta campos. Riesgo inherente: P3 x I4 = 12 (Alto). Riesgo residual: 3 (Bajo).	DTOs por caso de uso, enmascaramiento de DPI y cuenta, esquema de respuesta validado. Detectivo: Pruebas de contrato en CI. Correctivo: Corrección de la respuesta y análisis de exposición. Tratamiento: Mitigar | Iniciativa: R-02 | Responsable: Equipo Banca Digital | Fecha objetivo: 2026-12-31
11	T-11 Inyección SQL en filtros de movimientos	Tampering	Medium	Open	10	Parámetros de búsqueda concatenados en consultas permiten leer o modificar datos. Riesgo inherente: P2 x I5 = 10 (Medio). Riesgo residual: 4 (Bajo).	Consultas parametrizadas/ORM, validación de entrada, SAST (Semgrep) y DAST (ZAP) en el pipeline. Detectivo: Firmas WAF y alertas de errores SQL. Correctivo: Parche y revisión de datos afectados. Tratamiento: Mitigar | Iniciativa: R-02 | Responsable: Equipo Banca Digital | Fecha objetivo: 2026-12-31

BD Clientes e Identidad (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
24	T-24 Exfiltración de la base de clientes (PII)	Information disclosure	High	Open	15	Acceso a la base o a sus respaldos sin cifrar expone datos personales de todos los clientes. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	Cifrado TDE y a nivel de campo (DPI, teléfono), backups cifrados, segmentación, DAM. Detectivo: DAM con alertas de consultas masivas. Correctivo: Contención, notificación a afectados y a la SIB. Tratamiento: Mitigar | Iniciativa: R-16 | Responsable: DBA / Seguridad de la Información | Fecha objetivo: 2027-04-07

7.0 Middleware de Integración (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
45	T-45 Movimiento lateral hacia la zona de datos	Elevation of privilege	High	Open	15	Desde un servicio comprometido en DMZ o zona de aplicaciones el atacante alcanza el middleware y el core por una red plana. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	Microsegmentación, firewall entre zonas, mTLS obligatorio, Zero Trust. Detectivo: Detección de conexiones este-oeste no autorizadas. Correctivo: Aislamiento del segmento y respuesta a incidentes. Tratamiento: Mitigar | Iniciativa: R-12 | Responsable: Infraestructura y Redes | Fecha objetivo: 2027-07-31

Bóveda de secretos y HSM (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
49	T-49 Política permisiva en la bóveda de secretos	Elevation of privilege	Medium	Open	10	Políticas amplias permiten que un servicio lea secretos de otros servicios. Riesgo inherente: P2 x I5 = 10 (Medio). Riesgo residual: 4 (Bajo).	Políticas por servicio (mínimo privilegio), autenticación por identidad de carga de trabajo. Detectivo: Auditoría de accesos a la bóveda. Correctivo: Revocación y rotación de secretos. Tratamiento: Mitigar | Iniciativa: R-12 | Responsable: Infraestructura y Redes | Fecha objetivo: 2027-07-31

Proveedor SMS / Correo (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
37	T-37 Fuga de información en el proveedor de mensajería	Information disclosure	Medium	Open	6	Un compromiso del proveedor expone teléfonos, correos y contenido de alertas. Riesgo inherente: P2 x I3 = 6 (Medio). Riesgo residual: 3 (Bajo).	Cláusulas de seguridad y confidencialidad, mensajes sin datos sensibles. Detectivo: Evaluación anual del proveedor. Correctivo: Activación del plan de respuesta con el proveedor. Tratamiento: Transferir (contrato y cláusulas) + minimizar datos | Iniciativa: R-17 | Responsable: Seguridad de la Información / Compras | Fecha objetivo: 2027-08-31

Operador Back-office (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
30	T-30 Suplantación de un operador interno	Spoofing	High	Open	15	Credenciales de un operador obtenidas por phishing interno permiten operar el back-office. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	SSO con MFA resistente a phishing (Entra ID), acceso condicional solo desde dispositivos corporativos. Detectivo: Alertas de inicio de sesión riesgoso. Correctivo: Bloqueo de la cuenta y revisión de acciones realizadas. Tratamiento: Mitigar | Iniciativa: R-09 | Responsable: Operaciones / Seguridad de la Información | Fecha objetivo: 2027-03-15

8.0 Portal Back-office (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
29	T-29 Escalamiento de privilegios en back-office	Elevation of privilege	High	Open	15	Un operador accede a funciones de supervisor (cambio de límites, desbloqueos) por fallas de control de acceso. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	RBAC granular verificado en servidor, maker-checker, PAM para roles sensibles. Detectivo: Alertas por acciones fuera del rol. Correctivo: Revocación del acceso y revisión de cambios. Tratamiento: Mitigar | Iniciativa: R-09 | Responsable: Operaciones / Seguridad de la Información | Fecha objetivo: 2027-03-15
31	T-31 Repudio de cambios hechos por operadores	Repudiation	High	Open	12	Un operador niega haber modificado datos de un cliente y no hay evidencia suficiente. Riesgo inherente: P3 x I4 = 12 (Alto). Riesgo residual: 3 (Bajo).	Bitácora inmutable por acción con usuario, motivo y ticket; maker-checker. Detectivo: Revisión periódica de cambios sensibles. Correctivo: Investigación con evidencia y medidas disciplinarias. Tratamiento: Mitigar | Iniciativa: R-09 | Responsable: Operaciones / Seguridad de la Información | Fecha objetivo: 2027-03-15
32	T-32 Cambio fraudulento del teléfono o correo del cliente	Tampering	High	Open	15	Vía soporte se cambia el número asociado al OTP y luego se toma control de la cuenta. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	Verificación fuera de banda, periodo de enfriamiento de 48 h para transferencias tras el cambio, aviso al contacto anterior. Detectivo: Alerta por cambio de contacto seguido de alta de beneficiario o transferencia. Correctivo: Reversión del cambio y bloqueo de operaciones. Tratamiento: Mitigar | Iniciativa: R-09 | Responsable: Operaciones / Seguridad de la Información | Fecha objetivo: 2027-03-15

11.0 Pipeline CI/CD (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
27	T-27 Secretos embebidos en código y configuración	Information disclosure	Critical	Open	20	Contraseñas, API keys o certificados en el repositorio o en variables del pipeline son extraídos por un atacante o ex colaborador. Riesgo inherente: P4 x I5 = 20 (Crítico). Riesgo residual: 4 (Bajo).	Bóveda de secretos, secret scanning en pre-commit y pipeline, rotación periódica. Detectivo: Alertas del escáner y de uso de credenciales desde orígenes no esperados. Correctivo: Rotación inmediata y purga del historial. Tratamiento: Mitigar | Iniciativa: R-03 | Responsable: DevSecOps | Fecha objetivo: 2026-11-30
28	T-28 Compromiso de la cadena de suministro	Elevation of privilege	High	Open	15	Una dependencia maliciosa o un runner comprometido inyecta código en los artefactos desplegados. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	SCA (OWASP Dependency-Check) bloqueante, SBOM, firma y verificación de artefactos, revisión obligatoria de PR. Detectivo: Verificación de firma en el despliegue; alertas de nuevas dependencias. Correctivo: Rollback a artefacto firmado previo e investigación. Tratamiento: Mitigar | Iniciativa: R-13 | Responsable: DevSecOps | Fecha objetivo: 2027-06-30

Plataforma de logs / SIEM (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
33	T-33 Datos sensibles en bitácoras	Information disclosure	Medium	Open	9	Tokens, contraseñas o PAN quedan registrados en logs accesibles por más personas. Riesgo inherente: P3 x I3 = 9 (Medio). Riesgo residual: 3 (Bajo).	Enmascaramiento en origen, listas de campos prohibidos, control de acceso al SIEM. Detectivo: Búsquedas periódicas de patrones sensibles en logs. Correctivo: Purga y rotación de secretos expuestos. Tratamiento: Mitigar | Iniciativa: R-11 | Responsable: SOC | Fecha objetivo: 2027-02-28
34	T-34 Borrado o alteración de bitácoras	Tampering	Medium	Open	8	Un atacante con privilegios borra eventos para ocultar su actividad. Riesgo inherente: P2 x I4 = 8 (Medio). Riesgo residual: 3 (Bajo).	Envío en tiempo real, almacenamiento WORM, integridad por hash. Detectivo: Alertas por interrupción del envío de logs. Correctivo: Recuperación desde copia WORM. Tratamiento: Mitigar | Iniciativa: R-11 | Responsable: SOC | Fecha objetivo: 2027-02-28
35	T-35 Bitácoras insuficientes o sin sincronización de hora	Repudiation	Medium	Open	9	Eventos incompletos o con relojes desfasados impiden reconstruir un incidente. Riesgo inherente: P3 x I3 = 9 (Medio). Riesgo residual: 2 (Bajo).	Estándar de logging (OWASP Logging Cheat Sheet), NTP en todos los nodos. Detectivo: Revisión de cobertura de eventos en el SIEM. Correctivo: Ajuste de fuentes de log. Tratamiento: Mitigar | Iniciativa: R-11 | Responsable: SOC | Fecha objetivo: 2027-02-28

API REST + pinning (Data Flow)

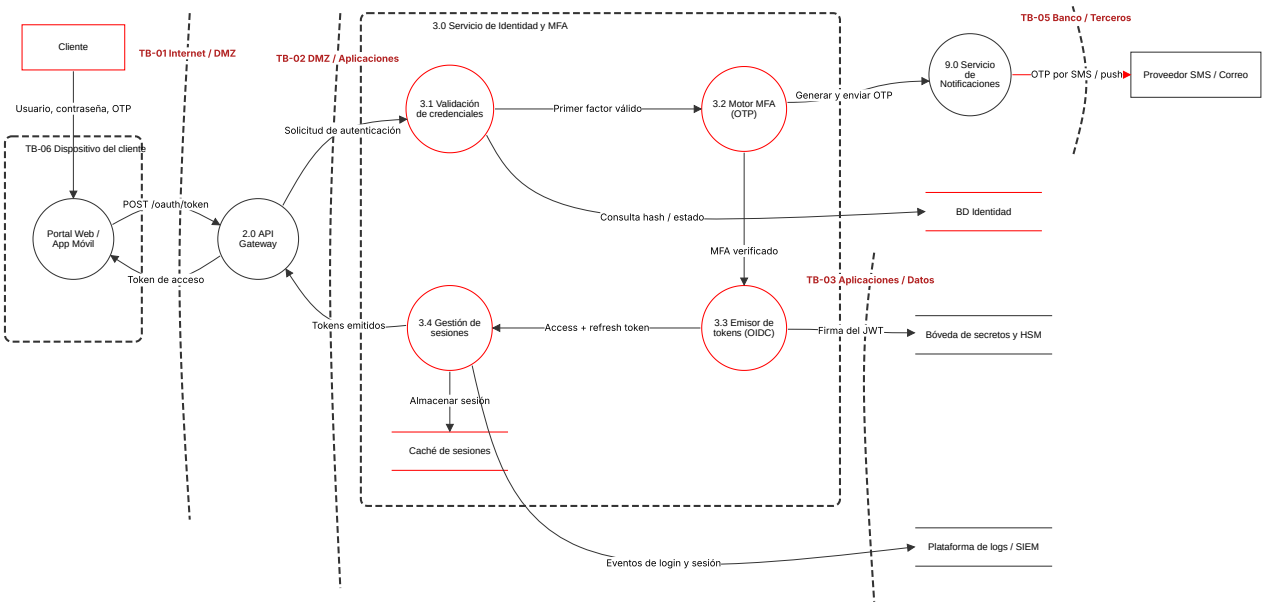
Number	Title	Type	Severity	Status	Score	Description	Mitigations
15	T-15 Interceptación del tráfico móvil (MitM)	Information disclosure	High	Open	12	Sin certificate pinning un atacante con un certificado instalado en el dispositivo lee y altera el tráfico. Riesgo inherente: P3 x I4 = 12 (Alto). Riesgo residual: 3 (Bajo).	TLS 1.3, certificate pinning, detección de root/jailbreak y de proxys. Detectivo: Telemetría de la app sobre fallos de pinning. Correctivo: Rotación de pines y actualización forzada de la app. Tratamiento: Mitigar | Iniciativa: R-10 | Responsable: Equipo Banca Digital | Fecha objetivo: 2027-03-31

Validación de DPI (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
43	T-43 Exposición o abuso de la consulta de DPI	Information disclosure	Medium	Open	8	La integración con RENAP es usada para enumerar ciudadanos o la respuesta completa se almacena sin necesidad. Riesgo inherente: P2 x I4 = 8 (Medio). Riesgo residual: 3 (Bajo).	Consulta solo con consentimiento y sesión de enrolamiento válida; almacenar solo el resultado de validación. Detectivo: Monitoreo de volumen de consultas. Correctivo: Suspensión de la integración y revisión. Tratamiento: Mitigar | Iniciativa: R-17 | Responsable: Seguridad de la Información / Compras | Fecha objetivo: 2027-08-31

DFD Nivel 2A — Autenticación, MFA y sesión

Descomposición del Servicio de Identidad y MFA (3.0).



DFD Nivel 2A — Autenticación, MFA y sesión

Cliente (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	T-01 Toma de cuenta por phishing (robo de credenciales)	Spoofing	Critical	Open	25	Un atacante clona el sitio del banco o envía enlaces maliciosos y obtiene usuario y contraseña del cliente para iniciar sesión en su nombre. Riesgo inherente: P5 x I5 = 25 (Crítico). Riesgo residual: 8 (Medio).	MFA push con number matching / FIDO2; detección de dispositivo nuevo; monitoreo y baja de dominios look-alike; educación al cliente. Detectivo: Alertas por inicio de sesión desde dispositivo, IP o país nuevo; correlación SIEM de login + alta de beneficiario. Correctivo: Bloqueo preventivo de la cuenta, reverso de operaciones, reseteo de credenciales y comunicación al cliente. Tratamiento: Mitigar + Transferir (póliza de ciberriesgo) | Iniciativa: R-01 | Responsable: Equipo IAM | Fecha objetivo: 2026-12-15

3.1 Validación de credenciales (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	T-02 Credential stuffing y fuerza bruta contra el login	Spoofing	Critical	Open	20	Uso automatizado de listas de credenciales filtradas en otros servicios para adivinar contraseñas de clientes. Riesgo inherente: P5 x I4 = 20 (Crítico). Riesgo residual: 6 (Medio).	Rate limiting por IP, cuenta y dispositivo; bloqueo progresivo; CAPTCHA adaptativo; verificación contra contraseñas filtradas. Detectivo: Regla SIEM: picos de autenticaciones fallidas y tasa de éxito anómala por ASN. Correctivo: Bloqueo de IP/ASN en WAF, reseteo forzado de contraseñas afectadas. Tratamiento: Mitigar | Iniciativa: R-01 | Responsable: Equipo IAM | Fecha objetivo: 2026-12-15
6	T-06 Enumeración de usuarios	Information disclosure	Medium	Open	8	Mensajes de error o tiempos de respuesta diferentes revelan si un usuario existe. Riesgo inherente: P4 x I2 = 8 (Medio). Riesgo residual: 2 (Bajo).	Mensajes genéricos y tiempos de respuesta constantes en login y recuperación. Detectivo: Detección de barridos de nombres de usuario. Correctivo: Ajuste de mensajes y bloqueo del origen. Tratamiento: Mitigar | Iniciativa: R-01 | Responsable: Equipo IAM | Fecha objetivo: 2026-12-15
47	T-47 Bloqueo masivo de cuentas inducido	Denial of service	Medium	Open	9	El atacante provoca bloqueos de cuentas legítimas con intentos fallidos deliberados. Riesgo inherente: P3 x I3 = 9 (Medio). Riesgo residual: 4 (Bajo).	Bloqueo temporal progresivo (no permanente), CAPTCHA, desbloqueo autoservicio con MFA. Detectivo: Alerta por volumen inusual de bloqueos. Correctivo: Desbloqueo masivo controlado y filtrado del origen. Tratamiento: Mitigar | Iniciativa: R-01 | Responsable: Equipo IAM | Fecha objetivo: 2026-12-15

3.2 Motor MFA (OTP) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	T-03 Interceptación del OTP por SIM swapping	Spoofing	Critical	Open	20	El atacante obtiene un duplicado de la SIM del cliente y recibe el OTP por SMS para completar el login o confirmar transferencias. Riesgo inherente: P4 x I5 = 20 (Crítico). Riesgo residual: 8 (Medio).	Consulta de cambio reciente de SIM con operadores antes de enviar OTP; migración a push/FIDO2; OTP ligado a la transacción. Detectivo: Alerta cuando el OTP se usa tras un cambio de SIM o desde dispositivo nuevo. Correctivo: Suspensión de canal SMS para la cuenta, verificación presencial o por videollamada. Tratamiento: Evitar (retirar SMS como factor principal) + Mitigar | Iniciativa: R-01 | Responsable: Equipo IAM | Fecha objetivo: 2026-12-15

3.3 Emisor de tokens (OIDC) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	T-04 Falsificación o aceptación indebida de tokens JWT	Spoofing	High	Open	15	Tokens aceptados con 'alg: none', claves débiles o sin validar iss/aud/exp permiten a un atacante fabricar identidades. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 5 (Bajo).	Firma RS256/ES256 con claves en HSM; validación estricta de iss, aud, exp y nbf en el API Gateway; rotación de claves JWKS. Detectivo: Registro de tokens rechazados y alertas por firmas inválidas. Correctivo: Rotación inmediata de claves y revocación de tokens activos. Tratamiento: Mitigar | Iniciativa: R-04 | Responsable: Arquitectura / DevSecOps | Fecha objetivo: 2026-12-31

3.4 Gestión de sesiones (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	T-05 Secuestro de sesión y reuso de refresh token	Spoofing	High	Open	16	Robo del token desde el dispositivo o vía XSS y reuso del refresh token para mantener acceso persistente. Riesgo inherente: P4 x I4 = 16 (Alto). Riesgo residual: 6 (Medio).	Tokens de acceso de vida corta (5 min); rotación de refresh token con detección de reuso; cookies HttpOnly/Secure/SameSite; DPoP. Detectivo: Alerta por uso concurrente de la misma sesión desde IPs distantes. Correctivo: Revocación de todas las sesiones del cliente y reautenticación. Tratamiento: Mitigar | Iniciativa: R-10 | Responsable: Equipo Banca Digital | Fecha objetivo: 2027-03-31

Caché de sesiones (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
36	T-36 Acceso no autenticado a Redis	Information disclosure	Medium	Open	8	Una instancia Redis sin autenticación o expuesta permite leer y alterar sesiones activas. Riesgo inherente: P2 x I4 = 8 (Medio). Riesgo residual: 3 (Bajo).	ACL y contraseña en Redis, TLS, red privada, deshabilitar comandos peligrosos. Detectivo: Escaneo de configuración y alertas de conexiones desde orígenes no autorizados. Correctivo: Rotación de credenciales e invalidación de sesiones. Tratamiento: Mitigar | Iniciativa: R-12 | Responsable: Infraestructura y Redes | Fecha objetivo: 2027-07-31

BD Identidad (Store)

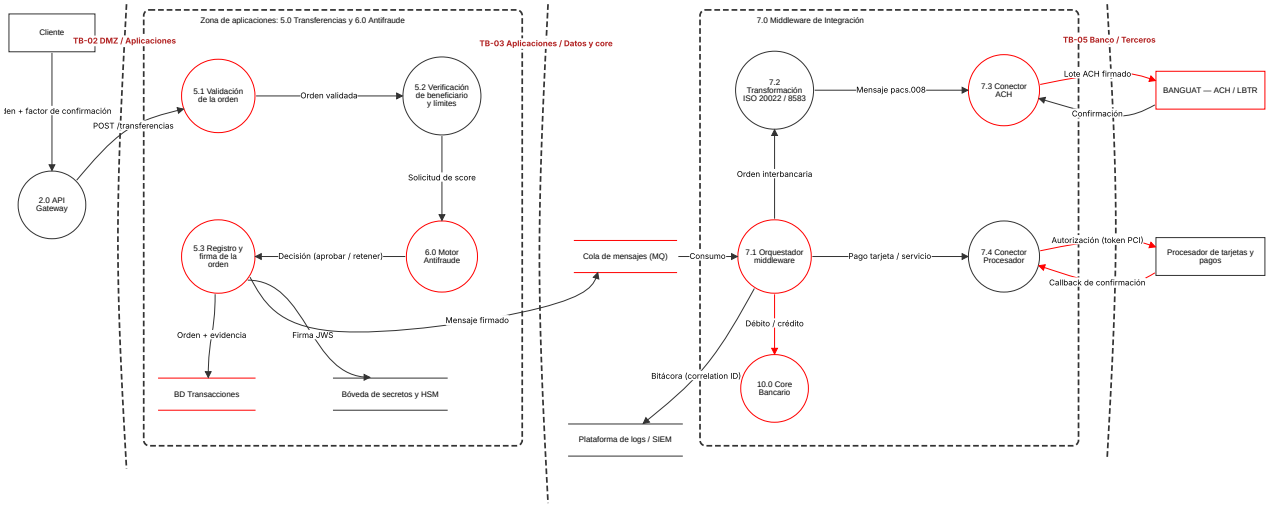
Number	Title	Type	Severity	Status	Score	Description	Mitigations
26	T-26 Hash de contraseñas débil	Information disclosure	Medium	Open	10	Si la base de identidad se filtra, algoritmos como MD5/SHA-1 permiten recuperar contraseñas. Riesgo inherente: P2 x I5 = 10 (Medio). Riesgo residual: 4 (Bajo).	Argon2id / bcrypt con sal y pepper en HSM. Detectivo: Auditoría de configuración del IdP. Correctivo: Rehash progresivo en el siguiente login y reseteo forzado si hay fuga. Tratamiento: Mitigar | Iniciativa: R-16 | Responsable: DBA / Seguridad de la Información | Fecha objetivo: 2027-04-07

OTP por SMS / push (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
38	T-38 Smishing que suplanta al banco	Spoofing	High	Open	12	Mensajes SMS falsos con el nombre del banco dirigen a los clientes a sitios de phishing. Riesgo inherente: P4 x I3 = 12 (Alto). Riesgo residual: 6 (Medio).	Registro de sender ID con operadores; mensajes sin enlaces; campañas de concientización. Detectivo: Monitoreo de reportes de clientes y de dominios fraudulentos. Correctivo: Solicitud de baja de dominios y bloqueo con operadores. Tratamiento: Mitigar | Iniciativa: R-07 | Responsable: Equipo IAM | Fecha objetivo: 2027-04-07

DFD Nivel 2B — Transferencias, middleware e integraciones bancarias

Descomposición de 5.0 Transferencias y 7.0 Middleware: antifraude, MQ, core, ACH y procesador.



DFD Nivel 2B — Transferencias, middleware e integraciones bancarias

5.1 Validación de la orden (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	T-08 Manipulación de parámetros de la transferencia	Tampering	Critical	Open	20	Interceptando la petición (proxy) se altera monto, cuenta origen o destino, o se añaden campos no previstos (mass assignment). Riesgo inherente: P4 x I5 = 20 (Crítico). Riesgo residual: 5 (Bajo).	Validación y recálculo server-side; esquema estricto de entrada (allowlist de campos); verificación de que la cuenta origen pertenece al usuario; firma de transacción. Detectivo: Alertas por discrepancia entre lo confirmado y lo ejecutado; pruebas DAST periódicas. Correctivo: Reverso de la operación y corrección del endpoint vulnerable. Tratamiento: Mitigar | Iniciativa: R-02 | Responsable: Equipo Banca Digital | Fecha objetivo: 2026-12-31

6.0 Motor Antifraude (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
39	T-39 Evasión del antifraude o fallo abierto	Elevation of privilege	High	Open	12	Fraccionamiento de montos bajo los umbrales o explotación de que, si el antifraude no responde, la transacción se aprueba (fail-open). Riesgo inherente: P3 x I4 = 12 (Alto). Riesgo residual: 6 (Medio).	Reglas acumulativas (velocidad, monto diario), fail-closed para montos altos, límites por beneficiario nuevo. Detectivo: Tableros de transacciones aprobadas sin score; alertas de fraccionamiento. Correctivo: Retención de fondos y revisión manual. Tratamiento: Mitigar | Iniciativa: R-15 | Responsable: Riesgo Operativo y Fraude | Fecha objetivo: 2027-10-07
40	T-40 Alteración de reglas antifraude	Tampering	Medium	Open	8	Un usuario interno modifica umbrales o listas blancas para dejar pasar operaciones fraudulentas. Riesgo inherente: P2 x I4 = 8 (Medio). Riesgo residual: 3 (Bajo).	Control de cambios con doble aprobación y versionado de reglas. Detectivo: Bitácora de cambios de reglas revisada por Riesgo. Correctivo: Reversión a la versión aprobada e investigación. Tratamiento: Mitigar | Iniciativa: R-15 | Responsable: Riesgo Operativo y Fraude | Fecha objetivo: 2027-10-07

5.3 Registro y firma de la orden (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	T-07 Repudio de transferencias por parte del cliente	Repudiation	High	Open	16	El cliente niega haber ordenado una transferencia y el banco no puede demostrar quién, cuándo y desde dónde la autorizó. Riesgo inherente: P4 x I4 = 16 (Alto). Riesgo residual: 4 (Bajo).	Firma de transacción con factor ligado a monto y destino; evidencia (dispositivo, IP, geolocalización, hash) firmada en HSM. Detectivo: Notificación en tiempo real al cliente; bitácora inmutable consultable por el área de reclamos. Correctivo: Proceso de disputa con evidencia firmada y conciliación. Tratamiento: Mitigar | Iniciativa: R-06 | Responsable: Equipo Banca Digital | Fecha objetivo: 2027-01-07

BD Transacciones (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
25	T-25 Modificación directa de registros por insider	Tampering	Medium	Open	10	Un DBA o cuenta privilegiada altera estados o montos directamente en la base de transacciones. Riesgo inherente: P2 x I5 = 10 (Medio). Riesgo residual: 4 (Bajo).	PAM con grabación de sesión, segregación de funciones, hash encadenado de registros. Detectivo: DAM con alertas sobre UPDATE/DELETE fuera de la aplicación. Correctivo: Restauración desde evidencia íntegra e investigación. Tratamiento: Mitigar | Iniciativa: R-16 | Responsable: DBA / Seguridad de la Información | Fecha objetivo: 2027-04-07

Cola de mensajes (MQ) (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
18	T-18 Inyección o alteración de órdenes en la cola	Tampering	High	Open	15	Con acceso a la cola, un atacante o insider inserta o modifica mensajes de órdenes antes de que el middleware los procese. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	Firma JWS por mensaje con clave en HSM verificada por el middleware; ACL por cola; cifrado TLS. Detectivo: Rechazo y alerta ante mensajes con firma inválida; conciliación BD transacciones vs core. Correctivo: Cuarentena de mensajes, reverso y rotación de credenciales MQ. Tratamiento: Mitigar | Iniciativa: R-08 | Responsable: Equipo de Integración | Fecha objetivo: 2027-03-31

7.1 Orquestador middleware (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
21	T-21 Falta de trazabilidad extremo a extremo	Repudiation	High	Open	12	Sin un identificador de correlación no es posible demostrar qué mensaje se envió al core o a BANGUAT ni quién lo originó. Riesgo inherente: P3 x I4 = 12 (Alto). Riesgo residual: 3 (Bajo).	Correlation ID desde el canal hasta ACH; bitácoras firmadas; conciliación diaria. Detectivo: Reportes de mensajes sin correlación. Correctivo: Reconstrucción con evidencia y corrección del flujo. Tratamiento: Mitigar | Iniciativa: R-11 | Responsable: SOC | Fecha objetivo: 2027-02-28

7.3 Conector ACH (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
19	T-19 Alteración de mensajes ACH antes del envío	Tampering	High	Open	15	Compromiso del conector permite cambiar la cuenta beneficiaria o el monto en el mensaje ISO 20022 hacia BANGUAT. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	Firma digital del mensaje en HSM, segregación de funciones, hash del lote verificado contra la orden original. Detectivo: Conciliación automática orden vs mensaje enviado; alertas por diferencias. Correctivo: Solicitud de reverso a BANGUAT y análisis forense. Tratamiento: Mitigar | Iniciativa: R-08 | Responsable: Equipo de Integración | Fecha objetivo: 2027-03-31

10.0 Core Bancario (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
22	T-22 Saturación del core bancario	Denial of service	High	Open	15	Picos de demanda (quincena, fin de mes) o reintentos en cascada agotan la capacidad del sistema legado. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 8 (Medio).	Circuit breakers, colas con reintento exponencial, throttling por canal, planificación de capacidad. Detectivo: Monitoreo de latencia y profundidad de colas. Correctivo: Activación de modo degradado (solo consultas) y plan de continuidad. Tratamiento: Mitigar | Iniciativa: R-14 | Responsable: Arquitectura / Operaciones TI | Fecha objetivo: 2027-09-30

BANGUAT — ACH / LBTR (Actor)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
42	T-42 Indisponibilidad de BANGUAT o del procesador	Denial of service	Medium	Open	8	Una caída del tercero impide liquidar transferencias interbancarias o pagos. Riesgo inherente: P2 x I4 = 8 (Medio). Riesgo residual: 8 (Medio).	Colas con reintento, ventanas de corte comunicadas, canal de contingencia. Detectivo: Monitoreo de disponibilidad del enlace. Correctivo: Comunicación a clientes y procesamiento diferido. Tratamiento: Aceptar (fuera del control del banco) + contingencia | Iniciativa: R-14 | Responsable: Arquitectura / Operaciones TI | Fecha objetivo: 2027-09-30

Débito / crédito (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
23	T-23 Credenciales de servicio con privilegios excesivos	Elevation of privilege	High	Open	15	El middleware usa una cuenta genérica con permisos administrativos sobre el core; si se compromete, el atacante opera sin límites. Riesgo inherente: P3 x I5 = 15 (Alto). Riesgo residual: 4 (Bajo).	Cuenta de servicio por integración con mínimo privilegio, rotación automática desde Vault. Detectivo: Alertas por uso de la cuenta fuera de patrón. Correctivo: Revocación y rotación de la credencial. Tratamiento: Mitigar | Iniciativa: R-12 | Responsable: Infraestructura y Redes | Fecha objetivo: 2027-07-31

Lote ACH firmado (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
20	T-20 Suplantación del extremo interbancario	Spoofing	Medium	Open	10	Un servidor falso (DNS spoofing o ruta alterna) se hace pasar por BANGUAT o por el procesador. Riesgo inherente: P2 x I5 = 10 (Medio). Riesgo residual: 4 (Bajo).	VPN IPsec dedicada, mTLS con certificados anclados, validación de huella del servidor. Detectivo: Monitoreo de cambios en certificados y rutas. Correctivo: Corte del enlace y conmutación al canal de contingencia. Tratamiento: Mitigar | Iniciativa: R-08 | Responsable: Equipo de Integración | Fecha objetivo: 2027-03-31

Autorización (token PCI) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
41	T-41 Exposición de datos de tarjeta	Information disclosure	Medium	Open	10	Datos de tarjeta en claro en tránsito o en logs del middleware. Riesgo inherente: P2 x I5 = 10 (Medio). Riesgo residual: 4 (Bajo).	Tokenización, cumplimiento PCI DSS v4.0, no almacenar CVV, mTLS. Detectivo: Escaneo de PAN en logs y almacenes. Correctivo: Purga de datos, notificación PCI. Tratamiento: Transferir (tokenización del procesador) + Mitigar | Iniciativa: R-08 | Responsable: Equipo de Integración | Fecha objetivo: 2027-03-31

Callback de confirmación (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
48	T-48 Callback de pago falsificado	Spoofing	High	Open	12	Un atacante envía una confirmación falsa de pago exitoso al endpoint de callback sin autenticación. Riesgo inherente: P3 x I4 = 12 (Alto). Riesgo residual: 3 (Bajo).	Verificación de firma HMAC del callback, allowlist de IP, consulta de confirmación al procesador. Detectivo: Conciliación diaria con el procesador. Correctivo: Reverso de pagos no confirmados. Tratamiento: Mitigar | Iniciativa: R-08 | Responsable: Equipo de Integración | Fecha objetivo: 2027-03-31